

# Points de contrôle ISO/IEC 27001:2022

## (Annexe A)

### Présentation

L'Annexe A de la norme ISO/IEC 27001:2022 recense **93 mesures de sécurité** réparties en quatre domaines. Ces mesures constituent le référentiel de contenu organisationnel et technologique de MUSA. Pour chaque mesure, l'auditeur évalue la conformité sur une échelle : **Conforme (C)**, **Partiellement conforme (PC)**, **Non conforme (NC)**, **Non applicable (NA)**.

### Domaine 5 : Mesures organisationnelles (37 mesures)

| Réf. | Mesure                                  | Objectif / Vérification                     | Éval. |
|------|-----------------------------------------|---------------------------------------------|-------|
| 5.1  | Politiques de sécurité de l'information | Existence, approbation direction, diffusion |       |
| 5.2  | Rôles et responsabilités en sécurité    | Attribution documentée des responsabilités  |       |
| 5.3  | Séparation des tâches                   | Contrôles prévenant conflits d'intérêts     |       |
| 5.4  | Responsabilités de la direction         | Engagement documenté de la direction        |       |
| 5.5  | Contact avec les autorités              | Procédure de contact établie                |       |
| 5.6  | Contact avec des groupes spécialisés    | Veille et participation à des groupes       |       |
| 5.7  | Renseignement sur les menaces           | Collecte et analyse des menaces             |       |
| 5.8  | Sécurité dans la gestion de projets     | Intégration sécurité dans les projets SI    |       |

| Réf. | Mesure                                                    | Objectif / Vérification                          | Éval. |
|------|-----------------------------------------------------------|--------------------------------------------------|-------|
| 5.9  | Inventaire des actifs                                     | Inventaire tenu, à jour, responsables identifiés |       |
| 5.10 | Utilisation acceptable des actifs                         | Règles d'usage définies et communiquées          |       |
| 5.11 | Restitution des actifs                                    | Procédure de récupération au départ              |       |
| 5.12 | Classification de l'information                           | Schéma de classification documenté               |       |
| 5.13 | Marquage de l'information                                 | Marquage cohérent avec la classification         |       |
| 5.14 | Transfert de l'information                                | Accords de transfert, chiffrement                |       |
| 5.15 | Contrôle d'accès                                          | Politique documentée, principe moindre privilège |       |
| 5.16 | Gestion des identités                                     | Cycle de vie des identités documenté             |       |
| 5.17 | Informations d'authentification                           | Règles de gestion des mots de passe              |       |
| 5.18 | Droits d'accès                                            | Attribution, revue et suppression formalisées    |       |
| 5.19 | Sécurité dans les relations avec les fournisseurs         | Clauses contractuelles de sécurité               |       |
| 5.20 | Prise en compte de la sécurité dans les accords           | Exigences de sécurité dans les contrats          |       |
| 5.21 | Gestion de la sécurité dans la chaîne d'approvisionnement | Contrôles sur les tiers                          |       |
| 5.22 | Surveillance et revue des services fournisseurs           | Audits réguliers des fournisseurs                |       |
| 5.23 | Sécurité des services cloud                               | Contrôles spécifiques aux services cloud         |       |
| 5.24 | Planification de la gestion des incidents                 | Procédure formalisée de gestion incidents        |       |
| 5.25 | Évaluation des événements de sécurité                     | Critères de qualification documentés             |       |
| 5.26 | Réponse aux incidents de sécurité                         | Plan de réponse testé                            |       |

| Réf. | Mesure                                 | Objectif / Vérification                           | Éval. |
|------|----------------------------------------|---------------------------------------------------|-------|
| 5.27 | Retour d'expérience sur les incidents  | Analyses post-incident documentées                |       |
| 5.28 | Collecte de preuves                    | Procédures forensiques définies                   |       |
| 5.29 | Sécurité des SI en cas de perturbation | Continuité testée régulièrement                   |       |
| 5.30 | Préparation des TIC pour la continuité | Plan de reprise documenté et testé                |       |
| 5.31 | Exigences légales et réglementaires    | Conformité aux lois (loi 2010/012 au Cameroun)    |       |
| 5.32 | Droits de propriété intellectuelle     | Licences logicielles vérifiées                    |       |
| 5.33 | Protection des enregistrements         | Politique de conservation documentée              |       |
| 5.34 | Protection de la vie privée            | Conformité aux lois sur la protection des données |       |
| 5.35 | Revue indépendante de la sécurité      | Audits internes/externes programmés               |       |
| 5.36 | Conformité aux politiques et normes    | Vérification régulière de conformité              |       |
| 5.37 | Procédures d'exploitation documentées  | Documentation à jour, accessible                  |       |

#### Domaine 6 : Mesures relatives aux personnes (8 mesures)

| Réf. | Mesure                                  | Objectif / Vérification               | Éval. |
|------|-----------------------------------------|---------------------------------------|-------|
| 6.1  | Présélection                            | Vérification des antécédents          |       |
| 6.2  | Termes et conditions d'emploi           | Clauses de confidentialité signées    |       |
| 6.3  | Sensibilisation, éducation et formation | Programme de sensibilisation annuel   |       |
| 6.4  | Processus disciplinaire                 | Procédure en cas de violation définie |       |

| Réf. | Mesure                                          | Objectif / Vérification                  | Éval. |
|------|-------------------------------------------------|------------------------------------------|-------|
| 6.5  | Responsabilités après cessation d'emploi        | Révocation des accès à la date de départ |       |
| 6.6  | Accords de confidentialité ou de non-divulgence | NDA signé par toutes les parties         |       |
| 6.7  | Travail à distance                              | Politique de télétravail sécurisé        |       |
| 6.8  | Signalement des événements de sécurité          | Canal de signalement connu des employés  |       |

#### Domaine 7 : Mesures physiques (14 mesures)

| Réf. | Mesure                                                       | Objectif / Vérification                   | Éval. |
|------|--------------------------------------------------------------|-------------------------------------------|-------|
| 7.1  | Périmètres de sécurité physique                              | Zones sécurisées délimitées et contrôlées |       |
| 7.2  | Entrée physique                                              | Accès contrôlé (badge, clé, biométrie)    |       |
| 7.3  | Sécurisation des bureaux, salles et équipements              | Zones sensibles verrouillées              |       |
| 7.4  | Surveillance physique                                        | Caméras, alarmes, journaux d'accès        |       |
| 7.5  | Protection contre les menaces physiques et environnementales | Protection incendie, inondation, coupure  |       |
| 7.6  | Travail dans les zones sécurisées                            | Règles définies pour les zones sensibles  |       |
| 7.7  | Bureau propre, écran propre                                  | Politique de bureau propre appliquée      |       |
| 7.8  | Emplacement et protection du matériel                        | Équipements protégés des risques env.     |       |
| 7.9  | Sécurité des actifs hors site                                | Protection des équipements mobiles        |       |
| 7.10 | Supports de stockage                                         | Procédure de destruction sécurisée        |       |
| 7.11 | Services généraux                                            | Alimentation électrique, climatisation    |       |

| Réf. | Mesure                                   | Objectif / Vérification                 | Éval. |
|------|------------------------------------------|-----------------------------------------|-------|
| 7.12 | Sécurité du câblage                      | Câblage protégé, documenté              |       |
| 7.13 | Maintenance du matériel                  | Maintenance planifiée et documentée     |       |
| 7.14 | Mise au rebut ou réutilisation sécurisée | Effacement sécurisé avant mise au rebut |       |

#### Domaine 8 : Mesures technologiques (34 mesures)

| Réf. | Mesure                                       | Objectif / Vérification                       | Éval. |
|------|----------------------------------------------|-----------------------------------------------|-------|
| 8.1  | Postes de travail des utilisateurs           | Configuration sécurisée, MAJ à jour           |       |
| 8.2  | Droits d'accès à privilèges                  | Comptes admin limités, supervisés             |       |
| 8.3  | Restriction d'accès à l'information          | Accès sur besoin d'en connaître               |       |
| 8.4  | Accès au code source                         | Code source contrôlé en version               |       |
| 8.5  | Authentification sécurisée                   | MFA activé pour accès sensibles               |       |
| 8.6  | Gestion de la capacité                       | Surveillance des ressources                   |       |
| 8.7  | Protection contre les logiciels malveillants | Antivirus déployé et à jour                   |       |
| 8.8  | Gestion des vulnérabilités techniques        | Scans réguliers, correctifs appliqués         |       |
| 8.9  | Gestion de la configuration                  | Configurations documentées et maîtrisées      |       |
| 8.10 | Suppression de l'information                 | Politique de suppression définies             |       |
| 8.11 | Masquage des données                         | Anonymisation dans les environnements de test |       |
| 8.12 | Prévention des fuites de données             | DLP ou contrôles équivalents                  |       |
| 8.13 | Sauvegarde de l'information                  | Sauvegardes planifiées, testées, hors site    |       |

| Réf. | Mesure                                             | Objectif / Vérification                          | Éval. |
|------|----------------------------------------------------|--------------------------------------------------|-------|
| 8.14 | Redondance des infrastructures                     | Tolérance aux pannes pour systèmes critiques     |       |
| 8.15 | Journalisation                                     | Journaux collectés, protégés, conservés          |       |
| 8.16 | Activités de surveillance                          | Surveillance en temps réel ou périodique         |       |
| 8.17 | Synchronisation des horloges                       | NTP configuré, synchronisation vérifiée          |       |
| 8.18 | Utilisation de programmes utilitaires à privilèges | Outils d'admin contrôlés                         |       |
| 8.19 | Installation de logiciels sur les systèmes         | Politique d'installation documentée              |       |
| 8.20 | Sécurité des réseaux                               | Segmentation, pare-feu, règles documentées       |       |
| 8.21 | Sécurité des services réseau                       | SLA de sécurité pour services réseau             |       |
| 8.22 | Filtrage de la navigation Web                      | Filtrage des URL malveillantes                   |       |
| 8.23 | Utilisation de la cryptographie                    | Politique cryptographique documentée             |       |
| 8.24 | Cycle de vie du développement sécurisé             | SDLC sécurisé documenté (DevSecOps)              |       |
| 8.25 | Sécurité dans le développement                     | Revue de code, SAST intégrés                     |       |
| 8.26 | Exigences de sécurité des applications             | Exigences de sécurité définies avant dev.        |       |
| 8.27 | Architecture de système sécurisé                   | Principes de sécurité appliqués à l'architecture |       |
| 8.28 | Codage sécurisé                                    | Guide de codage sécurisé documenté               |       |
| 8.29 | Tests de sécurité dans le développement            | Tests de sécurité intégrés au cycle              |       |
| 8.30 | Développement externalisé                          | Clauses de sécurité avec prestataires            |       |
| 8.31 | Séparation des environnements                      | Dev, test et production séparés                  |       |

| Réf. | Mesure                           | Objectif / Vérification              | Éval. |
|------|----------------------------------|--------------------------------------|-------|
| 8.32 | Gestion des changements          | Procédure de gestion des changements |       |
| 8.33 | Informations de test             | Données de test anonymisées          |       |
| 8.34 | Protection des systèmes en audit | Accès d'audit contrôlé et documenté  |       |